

DATA LOSS PREVENTION (DLP) POLICY & IMPLEMENTATION STRATEGY

Policy Owner:	IT Governance
Author:	Morolake Bolarinwa
Version:	1.0 (Final)
Effective Date:	September 2026

1. EXECUTIVE SUMMARY & POLICY OBJECTIVES

Purpose: The purpose of this Data Loss Prevention (DLP) Policy is to establish a standardized framework for identifying, monitoring, and protecting sensitive financial and customer data across the organization's hybrid cloud infrastructure (Microsoft 365, Azure).

Objectives:

- Prevent unauthorized exfiltration, accidental sharing, or misuse of protected information (e.g., PII, PCI-DSS, GLBA data).
- Enforce automated data protection controls across endpoints, cloud storage (OneDrive/SharePoint), and email (Exchange).
- Establish a clear incident response matrix for triage and escalation of DLP alerts.

Scope: This policy applies to all employees, contractors, and third-party vendors accessing enterprise information systems.

2. DATA CLASSIFICATION FRAMEWORK

To ensure the DLP engine applies the correct enforcement actions, all data must be classified into one of the following four tiers:

Classification Tier	Description & Examples	Automated DLP Action
Tier 1: Public	Intended for public distribution (marketing, press releases).	Monitor only; no restrictions.
Tier 2: Internal	Routine business communications and internal documentation not intended for public release.	Monitor; warn user upon external sharing.
Tier 3: Confidential:	Sensitive business data, intellectual property, or aggregate employee data.	Block external sharing via unencrypted channels; require manager approval for USB transfer.
Tier 4: Restricted	Financial/PII: Highly sensitive data regulated by federal law, including Social Security Numbers, Credit Card details (PCI), and customer financial records (GLBA).	Strictly block all external sharing; enforce mandatory encryption; trigger a high-severity alert to SOC.

3. MICROSOFT PURVIEW / CLOUD DLP IMPLEMENTATION STRATEGY

3.1. Scope of Technical Enforcement

To enforce the Data Classification Framework, DLP policies will be technically configured and deployed across the following Microsoft 365 and Azure environments:

- **Exchange Online:** Scanning all outbound email communications and attachments for sensitive data.
- **SharePoint Online & OneDrive for Business:** Scanning files at rest and preventing unauthorized external link sharing.
- **Endpoint DLP:** Enforcing data movement controls (e.g., blocking USB transfers, restricting copy/paste to unapproved browsers) on Entra ID-joined Windows devices.

3.2. Sensitive Information Types (SITs) Configuration

The Microsoft Purview compliance portal will be configured to automatically detect the following out-of-the-box and custom Sensitive Information Types (SITs) to protect financial and PII data:

- **PCI-DSS Data:** U.S. / U.K. Credit Card Numbers, SWIFT Codes.
- **PII & GLBA Data:** U.S. Social Security Numbers (SSN), U.S. Bank Account Numbers, Employer Identification Numbers (EIN).
- **Custom SITs:** Proprietary internal project codenames and specific KYC documentation templates.

3.3. DLP Rule Actions & User Experience

When a user attempts to share or exfiltrate data that violates the classification tiers, the Purview DLP engine will execute the following automated actions:

- **Policy Tips:** Users attempting to share Tier 2 (Internal) data externally will receive a real-time pop-up tip explaining the policy and warning them of the risk before the action is completed.
- **Block with Override:** For Tier 3 (Confidential) data, external sharing will be blocked, but users can provide a business justification to override the block. This justification is logged for audit purposes.
- **Strict Block:** For Tier 4 (Restricted) financial/PCI data, the action is immediately blocked with no user override permitted.

3.4. Telemetry & SIEM Integration

To ensure continuous monitoring and rapid incident response, all triggered DLP policy matches, user overrides, and blocked actions will be forwarded from Microsoft Purview to the enterprise SIEM (Microsoft Sentinel). This ensures the SOC and Governance teams have centralized visibility into high-risk data movement.

4. INCIDENT RESPONSE & ESCALATION MATRIX

To ensure standardized handling of DLP alerts forwarded from Microsoft Purview to Microsoft Sentinel, the Governance and Security Operations Center (SOC) teams will adhere to the following response matrix:

Severity Level	Alert Trigger	Required SOC / Governance Action
----------------	---------------	----------------------------------

Low (Tier 2 Internal Data)	User triggers a Policy Tip.	Event is logged in SIEM for behavioral analytics. No immediate action required.
Medium (Tier 3 Confidential Data)	User overrides a block with a business justification.	Governance/SOC Analyst reviews within 4 hours. Automated email notification sent to user and their direct manager for verification.
High (Tier 4 Restricted/PII Data)	Attempted exfiltration to an unverified external domain or USB device.	Immediate strict block by Purview. High-priority (P1) alert generated in Sentinel. Analyst investigates within 15 minutes.

5. EMPLOYEE TRAINING & EXCEPTION HANDLING

Training: All employees and contractors must complete Data Privacy and DLP awareness training during onboarding and annually thereafter.

Policy Exceptions: If a specific business unit requires a temporary exception to this policy (e.g., bulk exporting Tier 3 data for a legal audit), a formal Risk Acceptance Request must be submitted to the IT Governance team. Exceptions are valid for a maximum of 90 days and require CISO approval.